MEDIROZA GENERAL HOSPITAL

Penetration Testing & Security Assessment Project

Networkwalks Cybersecurity Internship • Batch B083 • Week 4

Prepared by: HAMZA AHMAD

Authorized Educational Lab Assessment

Target	https://medirozahospital.com
Assessment Type	Authorized web application penetration-testing lab
Primary Objective	Identify, validate, document, and remediate security weaknesses
Assessment Scope	Patient login, protected reports, PDF files, metadata, and exposed backup resources
Confidentiality	Educational / Lab Use

1. Project Overview

This project documents an authorized penetration-testing assessment of the Mediroza General Hospital lab environment. The assessment follows the supplied Networkwalks Week 4 solution and demonstrates how multiple weaknesses can be chained together: exposed application paths, username enumeration, SQL injection, weak PDF passwords, sensitive PDF metadata, and an exposed database backup.

The purpose is educational: to understand the attack path, collect evidence, determine business impact, and provide practical remediation guidance. The supplied source explicitly states that the target is authorized for security testing and that these techniques must not be used against systems without written permission.



2. Learning Objectives

- Perform structured reconnaissance against an authorized lab target.
- Identify authentication weaknesses such as username enumeration.
- Validate SQL injection in a controlled login form.
- Understand the security impact of weak password-protected PDF files.
- Extract and interpret PDF metadata after authorized decryption.
- Identify exposed directories and publicly accessible database backups.
- Trace related evidence across different findings.
- Produce a professional penetration-testing report with risk ratings and remediation.

3. Assessment Methodology

Milestone	Focus	Activities
Milestone 1	Initial Access	Reconnaissance → login discovery → username enumeration → SQL injection validation → authorized login bypass → report download
Milestone 2	Crack the Encryption	Extract PDF hashes → test supplied wordlists → use the instructor-provided JTR list where required → create an unlocked copy for analysis
Milestone 3	Deep Reconnaissance	Inspect PDF metadata → correlate clues → inspect exposed /old/ directory → identify database backup → correlate staff information

Milestone 4	Reporting	Consolidate vulnerabilities → assign risk → document business impact → provide remediation

4. Milestone 1 — Initial Access

4.1 Reconnaissance

The supplied solution begins by checking the target's robots.txt file for paths that reveal application areas.

Command:
curl https://medirozahospital.com/robots.txt

Observed paths in the supplied solution:

- /patient/ — target area for the milestone
- /staff/ — exposed path
- /old/ — later becomes relevant to the backup exposure

Evidence placeholder: [Insert screenshot of robots.txt response here]

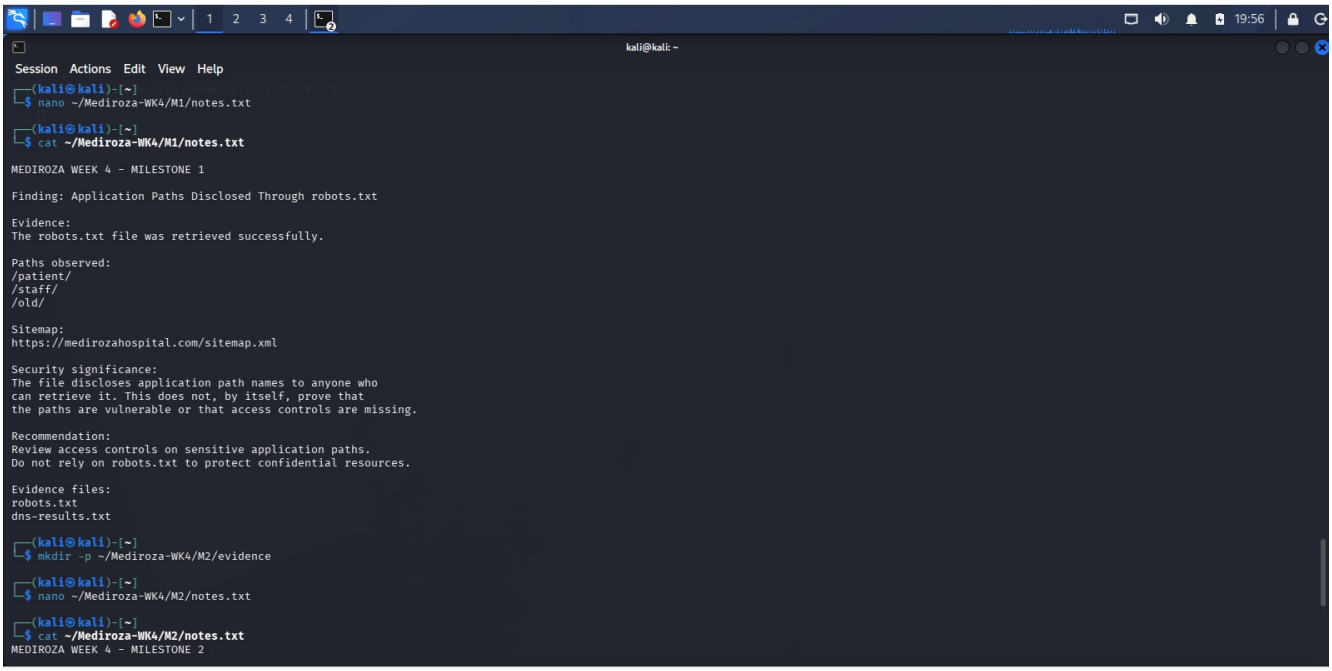
```
┌──(kali㉿kali)-[~]
└─$ nslookup medirozahospital.com
Server:         192.168.43.1
Address:        192.168.43.1#53

Non-authoritative answer:
Name:   medirozahospital.com
Address: 199.188.201.16


┌──(kali㉿kali)-[~]
└─$ curl -sS https://medirozahospital.com/robots.txt
# robots.txt
User-agent: *
Disallow: /patient/
Disallow: /staff/
Disallow: /old/

Sitemap: https://medirozahospital.com/sitemap.xml

┌──(kali㉿kali)-[~]
└─$
```



4.2 Discover the Login Page

The /patient/ path reveals the patient login page:

https://medirozahospital.com/patient/login.php

Evidence placeholder: [Insert screenshot of login page here]

4.3 Username Enumeration

The lab demonstrates that different error messages are returned for a nonexistent username and an existing username. A fake account returns “Username not found,” while the admin account returns “Incorrect password.” This difference reveals that the admin account exists.

Test	Observed Response	Security Significance
Fake username + test password	Username not found	Username does not exist
admin + test password	Incorrect password	admin account is confirmed to exist

Finding: Username enumeration — Medium risk.

Evidence placeholder: [Insert screenshots of both responses]

4.4 SQL Injection Validation

The supplied lab solution validates SQL injection by entering a single quote into the username field and observing a database syntax error. This confirms that user input reaches the database query unsafely.

Evidence placeholder: [Insert screenshot of the database error response]

4.5 Authorized Login Bypass

Within the authorized lab, the supplied solution demonstrates that a crafted username input can alter the login query and bypass the password condition. The result is access to a portal containing three patient reports.

Evidence placeholder: [Insert screenshot of successful lab login and report list]

4.6 Report Collection

- patient_report_1.pdf
- patient_report_2.pdf
- patient_report_3.pdf

5. Milestone 2 — Crack the Encryption

The supplied solution next analyzes the password protection on the three downloaded PDF files. It explains that a hash is extracted from each encrypted PDF and tested against wordlists.

5.1 PDF Hash Extraction

The source uses the Networkwalks Hash Calculator and notes that the resulting PDF hash begins with pdf.

Evidence placeholder: [Insert hash-calculator screenshots with sensitive values handled appropriately]

5.2 Wordlist Testing Results

File	Lab Result
patient_report_1.pdf	Password recovered using the supplied built-in list
patient_report_2.pdf	Password recovered using the supplied built-in list
patient_report_3.pdf	Built-in list exhausted; instructor-provided JTR list required

5.3 Decryption for Metadata Analysis

The supplied solution creates an unlocked copy of report 3 so that metadata analysis can read the complete file properties. In the authorized lab, the source gives the qpdf decryption step using the recovered lab password.

Evidence placeholder: [Insert screenshot showing successful creation of report3_open.pdf]

6. Milestone 3 — Deep Reconnaissance

6.1 PDF Metadata

The unlocked report is examined with exiftool. The key fields documented by the supplied solution identify the author as j.malik and contain a comment directing attention to a database backup moved to /old/.

Metadata Field	Lab Observation
Author	j.malik
Comments	DB backup moved to /old/ before site migration, do not delete

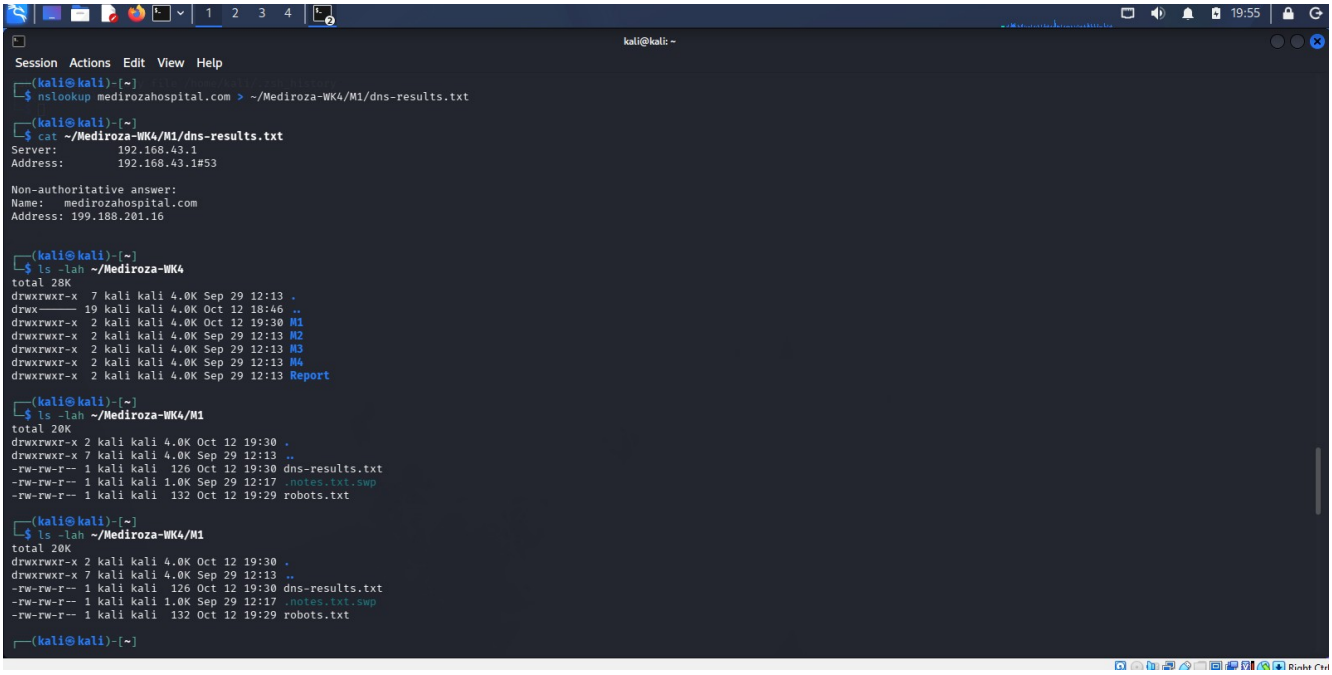
Evidence placeholder: [Insert exiftool output screenshot]

6.2 Exposed /old/ Directory

The /old/ path identified during reconnaissance is accessible and has directory listing enabled. The supplied solution documents a database backup named:

- mediroza_db_backup_2019.sql

Evidence placeholder: [Insert screenshot of authorized lab directory listing]


kali@kali: ~
Session Actions Edit View Help
┌──(kali㉿kali)-[~]
└─$ nslookup medirozahospital.com > ~/Mediroza-WK4/M1/dns-results.txt
┌──(kali㉿kali)-[~]
└─$ cat ~/Mediroza-WK4/M1/dns-results.txt
Server: 192.168.43.1
Address: 192.168.43.1#53
Non-authoritative answer:
Name: medirozahospital.com
Address: 199.188.201.16
┌──(kali㉿kali)-[~]
└─$ ls -lah ~/Mediroza-WK4
total 28K
drwxrwxr-x 7 kali kali 4.0K Sep 29 12:13 .
drwx------ 19 kali kali 4.0K Oct 12 18:46 ..
drwxrwxr-x 2 kali kali 4.0K Oct 12 19:30 M1
drwxrwxr-x 2 kali kali 4.0K Sep 29 12:13 M2
drwxrwxr-x 2 kali kali 4.0K Sep 29 12:13 M3
drwxrwxr-x 2 kali kali 4.0K Sep 29 12:13 M4
drwxrwxr-x 2 kali kali 4.0K Sep 29 12:13 Report
┌──(kali㉿kali)-[~]
└─$ ls -lah ~/Mediroza-WK4/M1
total 20K
drwxrwxr-x 2 kali kali 4.0K Oct 12 19:30 .
drwxrwxr-x 7 kali kali 4.0K Sep 29 12:13 ..
-rw-rw-r-- 1 kali kali 126 Oct 12 19:30 dns-results.txt
-rw-rw-r-- 1 kali kali 1.0K Sep 29 12:17 .notes.txt.swp
-rw-rw-r-- 1 kali kali 132 Oct 12 19:29 robots.txt
┌──(kali㉿kali)-[~]
└─$ ls -lah ~/Mediroza-WK4/M1
total 20K
drwxrwxr-x 2 kali kali 4.0K Oct 12 19:30 .
drwxrwxr-x 7 kali kali 4.0K Sep 29 12:13 ..
-rw-rw-r-- 1 kali kali 126 Oct 12 19:30 dns-results.txt
-rw-rw-r-- 1 kali kali 1.0K Sep 29 12:17 .notes.txt.swp
-rw-rw-r-- 1 kali kali 132 Oct 12 19:29 robots.txt
┌──(kali㉿kali)-[~]

6.3 Database Backup Analysis

The source explains that the SQL backup contains INSERT statements for staff and shareholders. The project analysis should present those records in readable tables while preserving confidentiality and using the lab data only.

Staff table evidence placeholder: [Paste the authorized lab staff INSERT rows here]

Shareholder table evidence placeholder: [Paste the authorized lab shareholder INSERT rows here]

Correlation: the source connects Jameel Malik in the staff table with the j.malik author metadata and identifies him as the IT Systems Administrator associated with the backup clue.

7. Final Findings Summary

#	**Vulnerability**	**Location**	**Risk**
1	Username enumeration	patient/login.php	Medium
2	SQL injection login bypass	patient/login.php	Critical
3	Encrypted PDFs accessible after login bypass	patient/reports/	High
4	Weak PDF passwords crackable with a wordlist	patient_report_*.pdf	High
5	Sensitive metadata left in patient PDF files	patient_report_3.pdf	Medium
6	Forgotten backup folder with directory listing enabled	old/	Critical
7	Confidential staff salaries and shareholder data in plain text	old/ mediroza_db_backup_2019.sql	Critical

8. Attack-Chain Narrative

1. Reconnaissance exposed the /patient/ and /old/ paths through robots.txt.
2. The patient login page disclosed valid usernames through different error messages.
3. SQL injection in the login form allowed the authorized lab tester to bypass authentication.
4. The authenticated portal exposed three encrypted patient reports.
5. Weak report passwords could be recovered with the supplied wordlists; the third required the instructor-provided JTR list.
6. Metadata in an unlocked report revealed a clue pointing to /old/.

7. Directory listing exposed a database backup containing sensitive organizational information.
8. The staff record for Jameel Malik correlated with the metadata author and completed the evidence chain.

9. Recommendations & Remediation

Finding	Recommended Remediation
Username enumeration	Return the same generic authentication error for invalid usernames and invalid passwords.
SQL injection	Use parameterized queries/prepared statements and never concatenate raw user input into SQL statements.
PDF access control	Keep sensitive PDFs outside the public web root or enforce robust authorization before download. Use strong unique passwords where encryption is required.
PDF metadata	Remove unnecessary metadata from patient documents before distribution. The supplied solution identifies exiftool as a cleaning option.
Directory listing / backup exposure	Disable directory listing, remove forgotten backup files, and never store database backups in a public web directory.
Sensitive database data	Restrict backup access, encrypt backups at rest, apply least privilege, and establish a retention/deletion process for obsolete backups.

10. Evidence Checklist

☐ robots.txt response

☐ Patient login page

☐ Username enumeration — both responses

☐ SQL injection error

☐ Successful authorized lab login

☐ Three report files

☐ PDF hash extraction

☐ Password-cracking results

☐ Unlocked report 3

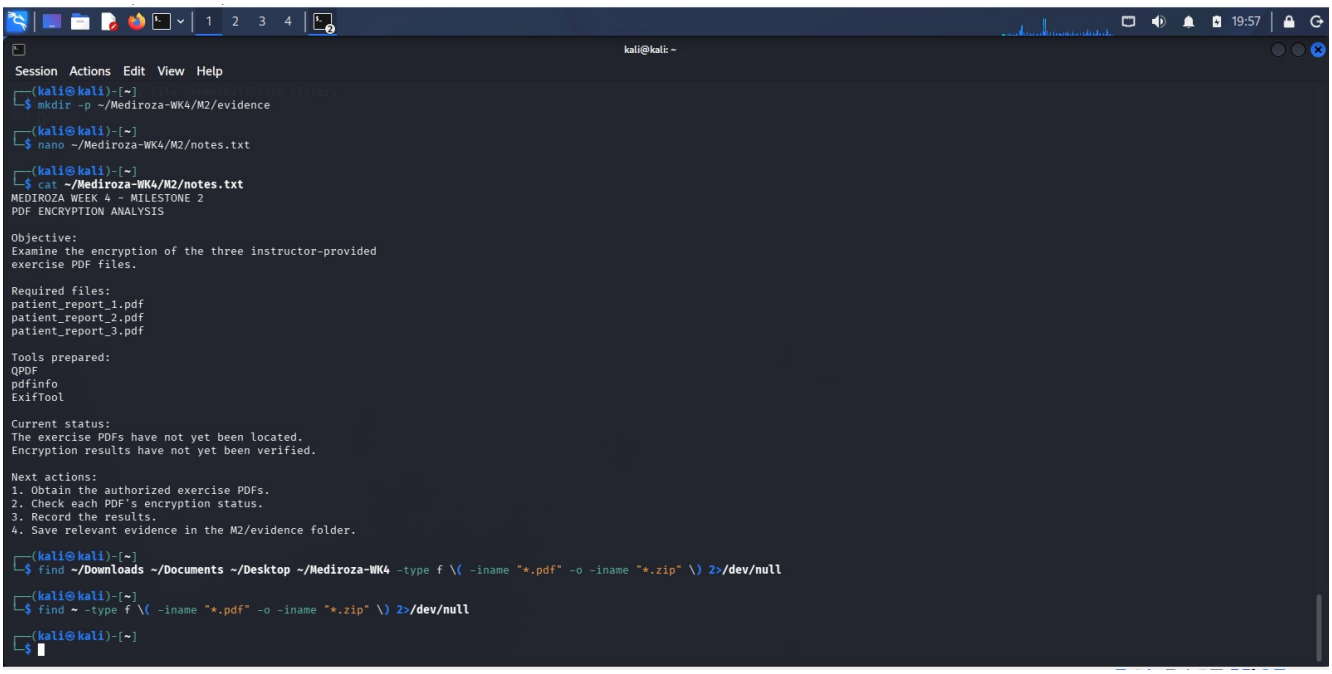
☐ exiftool metadata output

☐ /old/ directory listing

☐ Database backup filename

☐ Staff/shareholder extracted tables

☐ Final findings and remediation



11. Conclusion

The Mediroza lab demonstrates how individually significant weaknesses can combine into a broader security exposure. The assessment starts with simple reconnaissance and authentication testing, then progresses through protected document access, password weaknesses, metadata leakage, and finally an exposed database backup. The key lesson is that security controls must be implemented as a chain: fixing only one issue would not necessarily remove the entire attack path.

This project is based on the supplied Networkwalks Mediroza General Hospital Pentest Project Solution. The source explicitly limits the exercise to authorized security testing and educational use.

END OF PROJECT